
What Sets the Ceiling on Automated Code Audit: the Auditor, its Rulebook, or the Specification?

Zhaohe Dong¹

Abstract

An automated auditor reads code it did not write and decides whether to block it. We ask how much such an auditor catches and what decides the limit, against ground truth no model supplies: hidden test suites executed by an interpreter. Holding the auditor, its instructions and its ground truth fixed, and varying one thing at a time, we find the limit is set jointly by which model reads, what its rulebook tells it to look for, and whether the benchmark’s hidden suite asks a question the specification answers.

Repeated independent reading saturates far below complete. Eight readings of the shipped cross-vendor auditor reach 30.0% union recall on defective increments [20.0, 40.7], the eighth reading adding 1.9 points; twenty readings pooled across three auditor families reach 48.2% [36.7, 60.0]. Replacing the auditor with a stronger same-vendor model moves union recall by -26.4 points $[-37.3, -15.6]$, a preregistered primary, so a stronger model is a worse auditor here. Adding one sentence to the auditor’s rulebook, telling it to look for what the visible tests do not cover, moves flags by $+26.8$ points [13.6, 40.4], the largest effect we measure.

Much of what the auditor misses turns out to be failure the specification never determined. Under a rule that asks whether the prose settles the hidden suite’s expected value, two raters agree that 44 of the 57 never-flagged defects are cases where it does not, reversing the same instances’ earlier classification and withdrawing a claim this work previously made. Where an outside party had independently flagged one of these specifications as defective, our raters agree on 9 of the 11 tasks that overlap.

Two cautions follow for work that reports critic

and reviewer recall. First, a union-recall figure is contingent on the matching rate on correct work: on a second substrate with three times longer specifications the same auditor reaches more than twice the recall while flagging more than three times as much correct code, and for that auditor the two substrates’ false-positive intervals never meet, so no reading count offers a matched comparison. Second, repeated reading buys coverage in proportion to how much of the population sits near the auditor’s decision boundary: one auditor we measure returns an identical verdict on all 250 instances across eight independent readings while its replies, costs and latencies vary, so its union over K readings is flat by construction.

Every study was preregistered before its first model call, with hypotheses, intervals, kill conditions and stopping rules fixed in advance; four preregistered hypotheses were killed by their own rules. Every report was reviewed by a model from a different vendor with access to the raw records, and the reviews are archived verbatim beside the results they judge.

1. Introduction

An automated auditor reads code it did not write and says whether to block it. We ask how much such an auditor catches, and what decides the limit.

That question decomposes. A reviewer’s score on a benchmark mixes at least four things together: whether the model can see a defect, whether it judges the defect worth blocking on, whether the benchmark’s hidden tests define the behaviour it would have to see, and how many times it is allowed to look. Work on code-review and critic models improves the first two and reports the aggregate gain. We hold the auditor, its instructions and its ground truth fixed, and vary the other three one at a time, against a truth no model supplies: a hidden test suite executed by an interpreter.

Reading again saturates. Eight independent readings of the same increment by the shipped cross-vendor auditor reach 30.0% union recall on defective increments, with a

¹Independent researcher. Correspondence to: Zhaohe Dong <dongzhaohe321418@gmail.com>.

95% problem-cluster interval of 20.0 to 40.7, and the eighth reading adds 1.9 points. Twenty readings pooled across three auditor families reach 48.2%. More sampling leaves that limit where it is.

The auditor and its instructions do move it. Swapping in a stronger model of the generator’s own vendor changes union recall by -26.4 points [-37.3, -15.6], a preregistered primary: a stronger model is a worse auditor here. Adding one sentence to the auditor’s rulebook, telling it to look for what the visible tests do not cover, moves flags by +26.8 points [13.6, 40.4], which is the largest effect we measure, and it costs enough false positives to put the rule outside the product’s own constraint.

Much of what the auditor misses turns out to be failure the specification never determined. We re-rated the never-flagged residual under a rule that asks whether the prose settles the hidden suite’s expected value before it asks whether the visible tests exercised the input. Two raters agree that 44 of 57 residual instances are cases where the prose does not settle it, reversing the same instances’ earlier classification. Where an outside party had already flagged one of these specifications as defective, for their own purposes and before we looked, our raters agree on 9 of the 11 tasks that overlap.

We then built a population where specification-determinedness holds by construction and audited it with the same auditor and the same eight readings. Recall goes from roughly a third to 90 of 92, and one reading is worth almost as much as eight. The claim this supports is a bound: the measured ceiling lies above what the auditor can do on defects the specification settles. How often natural defects of that kind are caught remains open, because the constructed defects are detectably artificial, with a frontier model separating them from natural ones at 96.7%. We measured that separability rather than assuming it away.

The headline number does not travel either. On a second substrate whose specifications run three times longer and whose solutions run seven times longer, the same auditor reaches more than twice the recall while flagging more than three times as much correct work, and buys less recall per false positive at every reading count. For the cross-vendor auditor the two substrates’ false-positive intervals never meet, so no reading count offers a matched operating point. A union recall figure is therefore contingent on the false-positive rate it cost, and the ceiling we measure describes an operating point.

1.1. Preregistration and review

Every study was preregistered before its first model call, with hypotheses, intervals, kill conditions and stopping rules fixed in advance, and every departure recorded as a num-

bered amendment that says what was known at the time. Four preregistered hypotheses were killed by their own rules, two of them our own conjectures. Every report was reviewed by a model from a different vendor with access to the raw records, and no report entered this manuscript until such a review approved it; several needed many rounds, and the reviews are archived verbatim beside the results they judge. We record this as method, and it is what lets a reader read the negative results here as measurements.

2. Method

2.1. Substrates and ground truth

Both substrates are Python functions with executable hidden test suites, so every stratum, recall denominator and false-positive population is decided by an interpreter and no model judges any outcome. **Substrate 1** is HumanEval+ and MBPP+ (EvalPlus), whose median task is 41 words of prose and 6 lines of reference code, with the benchmark’s base suite shown to the author and its plus suite held back. **Substrate 2** is the standard-library half of BigCodeBench, whose median task is 118 words and 41 lines. BigCodeBench ships one test class per task, so the visible and hidden suites are separated here: two test methods chosen by a fixed seed are the visible suite and all methods are the hidden suite, with the class run unmodified and told which methods to execute. Tasks whose declared modules are unavailable in the frozen interpreter, or whose reference solution fails its own suite there, are dropped before generation and counted.

Candidates are written by one generator shown the specification and the visible tests. A candidate that passes the visible suite and fails the hidden one is a **defective** instance; one that passes both is **correct**; one that fails the visible suite is discarded. Recall is measured on the defective stratum and false positives on a sample of the correct stratum.

2.2. The auditor and the estimand

The auditor reads the specification, the visible tests and the candidate, and returns findings with severities; an increment is blocked when any finding is graded BLOCKER. It never sees the hidden suite. The estimand throughout is **union recall at K** : the fraction of defective instances blocked by at least one of K independent readings, averaged exactly over all $\binom{K_{\max}}{K}$ subsets rather than by sampling. The matching quantity on the correct stratum is the union false-positive rate. A union recall figure is reported only beside the false-positive rate it cost.

2.3. Statistics

The independent unit is the instance and the resampling unit is the problem, because problems recur across generation batches. Every rate carries a 95% percentile bootstrap over whole problem clusters (10,000 resamples, seeds fixed in each preregistration), with the Wilson interval printed beside it and marked as too narrow. Paired contrasts carry an exact McNemar test and a cluster-level sign-flip permutation test; where every discordant pair points one way the percentile bootstrap's bound at zero is an artefact and an exact unconditional interval is quoted instead. A saturation curve is summarised by a constrained exponential fit, and the fitted asymptote is quoted only when the preregistered flattening bar is met; otherwise it is labelled an extrapolation and the raw union at $K_{\max}$ is the number quoted. Counts of five or fewer are quoted as counts.

2.4. Preregistration and independent review

Each study was preregistered before its first model call, fixing its population, hypotheses, primary outcome, intervals, kill conditions, budget and stopping rule. Departures are numbered amendments committed before the step they govern, each recording what was known at the time; where an amendment followed an interim observation, the results say so and argue whether the change could favour the hypothesis. Each report was then reviewed by a model from a different vendor with read access to the raw records, asked to re-run the analysis, recompute the intervals independently, and check every sentence against the records. No report entered this paper until such a review ended in approval. Reviews are archived verbatim, including those that refused approval, and several studies needed many rounds.

3. Results

Every figure in this section comes from a report that passed an independent cross-vendor review ending in approval, and carries the interval and the label that report gives it. The governing list is `CLAIMS.md`. Three further studies have reported and are in review, and none of their numbers appear here. Rates carry the 95% problem-cluster percentile bootstrap as the primary interval, with the Wilson interval beside it where the source report gives one, because problems recur across generation batches and an interval that treats instances as independent is too narrow.

3.1. 1. Reading again saturates below complete

The shipped cross-vendor auditor reads an increment holistically and returns findings; an increment is blocked if any finding is graded BLOCKER. Over eight independent readings of the same 110 defective instances, union recall rises from 10.7% at one reading to 30.0% [20.0, 40.7] at eight,

and the eighth reading adds 1.9 points. The constrained fit puts the asymptote at 31.5%, but the preregistered flattening bar was not met, so that asymptote is an extrapolation and the raw union at eight readings is the number to quote. Twenty readings pooled across three auditor families reach 48.2% [36.7, 60.0].

The price is measured on the same footing. Union false positives on 150 correct increments reach 16.0% [10.1, 22.3] at eight readings, and the recall bought per point of false positive falls monotonically as readings accumulate.

3.2. 2. The auditor and its instructions move the ceiling; repetition does not

Two interventions were compared against that baseline on the same frozen instances.

Replacing the auditor with a stronger model of the generator's own vendor moved union recall at eight readings by -26.4 points, cluster [-37.3, -15.6]. Three instances were flagged only by the new family and thirty-two only by the shipped auditor, at an exact McNemar p of 4.2×10^{-7} . This was a preregistered primary, and a stronger model is the worse auditor here.

Adding a single rule to the auditor's constitution, telling it to find what the visible tests do not cover, moved flags on the defect population by +26.8 points, cluster [13.6, 40.4], at a McNemar p of 0.0003. This is the largest effect measured anywhere in the programme, and it is exploratory: the preregistration named outcome contrasts rather than this one, and the number carries that label wherever it appears.

A same-vendor auditor was worse than the cross-vendor one on these instances by -12.7 points [-25.0, -0.9] of union recall at eight readings, signed so that a negative value favours the cross-vendor auditor. A later study on a second substrate reverses that sign, so this is reported as a measurement on this substrate rather than as a property of same-vendor auditing.

3.3. 3. Most of what the auditor missed is failure the specification never determined

Fifty-seven of the 110 defective instances were flagged by no reading of any family. The first classification of that residual asked whether the visible tests exercised the failing input before it asked anything else. It called 46 of 57 unexercised edges, and an earlier draft of this paper rested a claim on that.

Re-rating the same instances under a rule that asks first whether the specification's prose determines the hidden suite's expected value reverses it. Two raters agree that 44 of 57 (77.2%, cluster [62.1, 91.1]) are cases where the prose does not settle the value, and that 2 of 57 are cases

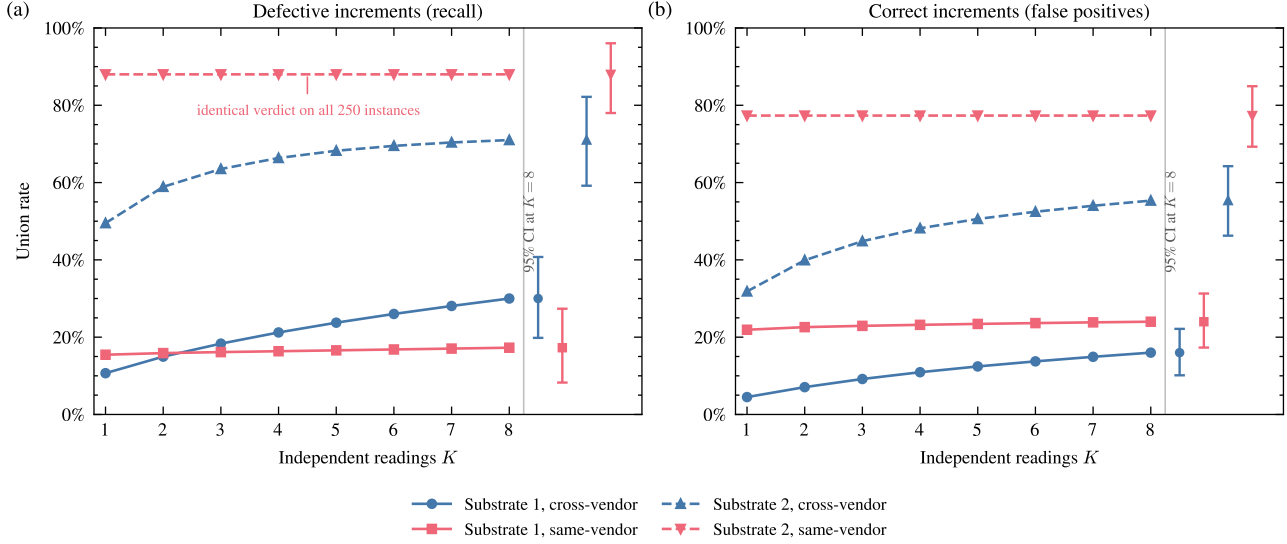


Figure 1. Reading again saturates, and where it saturates depends on the substrate. Union rate against the number of independent readings K , for two auditor families on two substrates. (a) recall on defective increments; (b) false positives on correct increments. Bars at the right of each panel give the 95% problem-cluster bootstrap interval of each series at $K = 8$, dodged in x so overlapping intervals stay separable. The same-vendor auditor on substrate 2 is flat because its verdict is identical on all 250 instances across all eight readings.

where it does and the visible tests merely never built the input. The preregistered condition for withdrawing “the residual is mostly unexercised edge” fires on both of its clauses, and the claim is withdrawn.

A classification that reverses when the order of its questions changes is, by itself, weak evidence about the auditor. Two things support the second reading. It was fixed before any label was written, and its labels were committed before we looked for outside evidence. And where an outside party had independently recorded that one of these specifications is defective, in twelve MBPP tasks named in a paper written for another purpose, our raters agree on 9 of the 11 that fall inside our defect population, with both disagreements on the boundary that paper’s own “incomplete” category draws. That check is one-sided by construction: it can support agreement where an outsider looked, and can bound nothing about the rate.

3.4. 4. What follows for a recall number

Taken together, the results above say an audit recall figure is a joint property of the auditor and its material. It moves with which model reads, with what the rulebook tells it to look for, and with whether the benchmark’s hidden suite asks a question the specification answers. The studies now in review test the last of these prospectively, measure the ceiling on a second substrate, and adjudicate whether a flag is a naming; where they bear on the claims above, CLAIMS.md records what they would change.

4. Discussion

4.1. What a union-recall number means

We report the shipped auditor’s union recall over eight independent readings as 30.0% on one substrate and 71.0% on another, and both figures are contingent on the rate they cost. On the second substrate the same auditor flags 55.3% of correct work where it flagged 16.0% on the first, and it buys less recall per unit of false-positive cost at every reading count. A single reading on the second substrate already costs more false positives than eight readings on the first: 31.8% [24.9, 39.0] against 16.0% [10.1, 22.3], intervals that do not meet. For the cross-vendor auditor, then, no reading count gives a matched false-positive rate across the two substrates. That holds for the cross-vendor auditor, which is the one the headline uses. Pooling the families breaks it, because substrate 1’s same-vendor auditor reaches 24.0% [17.2, 31.2], which overlaps substrate 2’s range. An earlier draft asserted the unrestricted version on point estimates alone, and a review of the figures caught it.

An auditor’s recall is a property of where it stands on its own trade-off, and the trade-off moves with the material, so the two substrates measure one auditor at two operating points. Comparisons of reviewers and critics that report recall, F1 or win rates without the corresponding rate on correct work are comparing operating points that need not be the same.

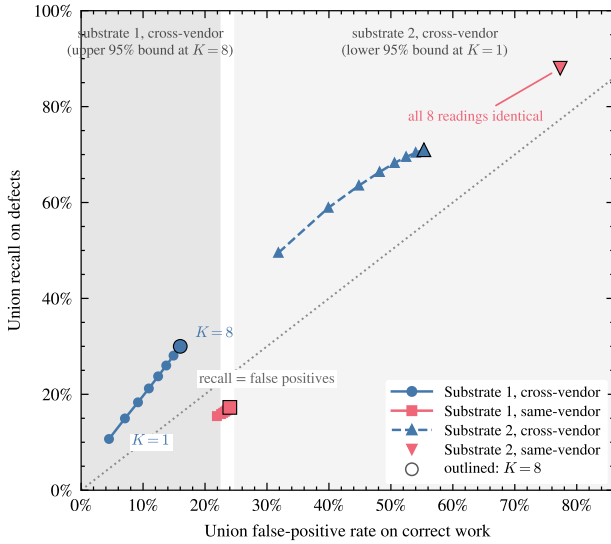


Figure 2. Recall and false positives move together, and for the cross-vendor auditor the two substrates never meet. Each track is one auditor family on one substrate from $K = 1$ to $K = 8$; the outlined marker is $K = 8$. The shaded spans are *bounds*: the left ends at the upper 95% bound of the cross-vendor auditor’s false-positive rate on substrate 1 at $K = 8$ (22.3%), the right begins at its lower 95% bound on substrate 2 at $K = 1$ (24.9%). Pooling the two auditor families the ranges *do* overlap, so the claim is made for the cross-vendor auditor alone.

4.2. Repeated reading buys coverage only where the decision is marginal

Union-of-K is the instrument this paper uses to find a ceiling, and on the second substrate the same-vendor auditor shows what it measures when it measures nothing. That auditor’s block decision is identical across all eight independent readings on every one of 250 instances, while its reply text, cost and latency vary. Its union curve is flat, and the registered efficiency ratio, which divides by the gain in false positives over one reading, is undefined rather than large.

The explanation is the operating point. On the second substrate that auditor flags 88% of defective and 77% of correct increments, so almost nothing sits near its decision boundary and resampling has nothing to flip; the same model splits its verdict on 9 of 260 instances on the first substrate, where it flags far less. The cross-vendor auditor, at 71% and 55%, splits on 103 of 250.

Best-of-K, union-of-K and panel aggregation over critics therefore buy coverage in proportion to how much of the population sits near the critic’s boundary. An auditor tuned loud enough is invariant under resampling, and its union over K readings can rise only as far as its marginal cases allow.

4.3. What the ceiling is made of

Three measured contributions account for most of it, and repetition is the smallest. Eight readings of one auditor buy 19.3 points of recall, and twenty readings across three families leave 51.8% of the defect population untouched. Changing which model reads moves the same quantity by 26.4 points, and changing one sentence of the rulebook moves flags by 26.8. The largest contribution belongs to the benchmark rather than to the auditor: under a rule that asks whether the specification’s prose determines the hidden suite’s expected value, 44 of the 57 never-flagged defects fail that test, and a constructed population where the prose does determine the answer is audited at 90 of 92 by the same auditor reading once.

The constructed population carries a limitation we measured rather than assumed. Its defects are detectably artificial: a frontier model separates them from natural ones at 96.7%. What the construction licenses is a bound, that the measured ceiling lies above what an auditor can do on defects the specification settles, and it leaves open how often natural defects of that kind are caught.

4.4. Flagging is not naming

An audit that blocks an increment for the wrong reason has still blocked it, and a recall number counts that as a catch. With the finding texts kept for one reading of the shipped auditor and adjudicated blind by two raters, the auditor returned a finding on 9 of 110 defective instances and asserted the actual failing behaviour on 5 to 7 of them, depending on how the two raters are combined. The raters agreed at $\kappa = 0.391$, which we report beside the rate it produces, because a moderate agreement is part of what the rate is worth.

4.5. Limits

Both substrates are short, self-contained Python functions with executable hidden tests, so nothing here measures auditing a change to a large program with no oracle. The generator is a single model on both substrates. The residual rubric’s raters were the author and a model; one external label set agrees with them across eleven overlapping tasks. The injected population’s defects are distinguishable from natural ones. Each of these is recorded in the study that carries it, together with the number it would change.

4.6. What we would do next

Adjudicating more than one reading of the shipped auditor would let a naming rate be compared with a union flag rate at the same K. A population of natural defects independently known to be specification-determined would separate the injected population’s artificiality from the property it was

built to isolate. And a substrate whose ground truth is not a hidden test suite would test the assumption every ceiling here rests on, which is that a test suite asked the right question.

5. Related work

Critics that read code. Trained critic models write natural-language critiques of model-written code and outperform unaided humans on inserted bugs (McAleese et al., 2024). Two differences bear on what a ceiling means. Such work is evaluated largely on inserted defects, which are specification-determined by construction, whereas our natural stratum is the residue of an ordinary generation run, where whether the specification determines the failure is the open question. And the reported quantity is a preference or a per-critique comparison rather than the union recall of repeated independent readings, so it does not say where reading saturates. Aggregating several review passes is known to help: multi-review aggregation on 1,000 verified pull requests raises F1 by up to 43.67% (Zeng et al., 2025). That is the same mechanical move as our union-of- K , used as a method rather than as an instrument for finding a limit.

What the hidden suite decides. EvalPlus rebuilt HumanEval and MBPP with larger suites and reported defects in the original reference solutions (Liu et al., 2023); its code carries bespoke oracles for tasks where differential testing against the reference was not applicable. Richter & Papadakis (2026) show that models collapse onto a single incorrect reading of an underspecified task and name twelve MBPP tasks they identified by hand; eleven fall inside our defect population and our raters, who labelled them before that paper was fetched, agree on nine. From the test-generation side, the dominant error in generated tests is a wrong expected value rather than an invalid input (Chen et al., 2023), and generated oracles tend to capture a program’s actual rather than its intended behaviour (Konstantinou et al., 2024). Our claim is the auditing counterpart: where the prose does not fix the value, a recall number computed against that suite measures the benchmark as much as the auditor.

Consensus as a substitute for ground truth. Several systems validate generated tests without a reference by agreement, through self-consistency, dual execution or multi-agent discussion (Anonymous, 2026a; 2025a). Neither reports how many wrong assertions survive the filter, which is the quantity that decides whether the filter can be trusted. We measure it on a frozen set of canonical-failing tests and find that corroboration across independent generations does not reach our preregistered threshold, because wrong tests recur by problem. This is the concrete case of a general result: self-consistent errors are exactly the class that consistency-based detectors cannot see (Tan et al., 2025).

Who audits whom. That an evaluator should not be the model under evaluation is supported by measurements of self-preference and family bias in LLM judges (Anonymous, 2025b). Our contribution is its size against model-free ground truth, and the finding that its direction is substrate-dependent.

Preregistration. Preregistering an evaluation protocol is beginning to appear in machine learning, both as a proposal for agent experiments and as a defence against tuning a pipeline until it reports what the author wanted (Anonymous, 2026b). We record our use of it as method rather than contribution.

Reproducibility and claims

The claims this paper is willing to defend, each with the interval and the label its source report gives it, are listed in CLAIMS.md in the accompanying repository, together with the claims the evidence does not support. Every preregistration, every numbered amendment, every report and every independent review is archived there verbatim.

References

- Anonymous. Hallucination to consensus: Multi-agent LLMs for end-to-end test generation with accurate oracles. *arXiv preprint arXiv:2506.02943*, 2025a.
- Anonymous. Do LLM evaluators prefer themselves for a reason? *arXiv preprint arXiv:2504.03846*, 2025b.
- Anonymous. Consistency meets verification: Enhancing test generation quality in large language models without ground-truth solutions. *arXiv preprint arXiv:2602.10522*, 2026a.
- Anonymous. Preregistration for experiments with AI agents. *arXiv preprint arXiv:2606.11217*, 2026b.
- Chen, W. et al. The program testing ability of large language models for code. *arXiv preprint arXiv:2310.05727*, 2023.
- Konstantinou, M. et al. Do LLMs generate test oracles that capture the actual or the expected program behaviour? *arXiv preprint arXiv:2410.21136*, 2024.
- Liu, J., Xia, C. S., Wang, Y., and Zhang, L. Is your code generated by ChatGPT really correct? rigorous evaluation of large language models for code generation. In *Advances in Neural Information Processing Systems*, 2023.
- McAleese, N., Pokorny, R. M., Uribe, J. F. C., Nitishinskaya, E., Trebacz, M., and Leike, J. LLM critics help catch LLM bugs. *arXiv preprint arXiv:2407.00215*, 2024.

Richter, C. and Papadakis, M. Underspecification does not imply incoherence: The risks of semantic collapse in coding models. *arXiv preprint arXiv:2607.01953*, 2026.

Tan et al. Self-consistent errors and the limits of consistency-based detection. *arXiv preprint*, 2025.

Zeng, Z. et al. Benchmarking and studying the LLM-based code review. *arXiv preprint arXiv:2509.01494*, 2025.